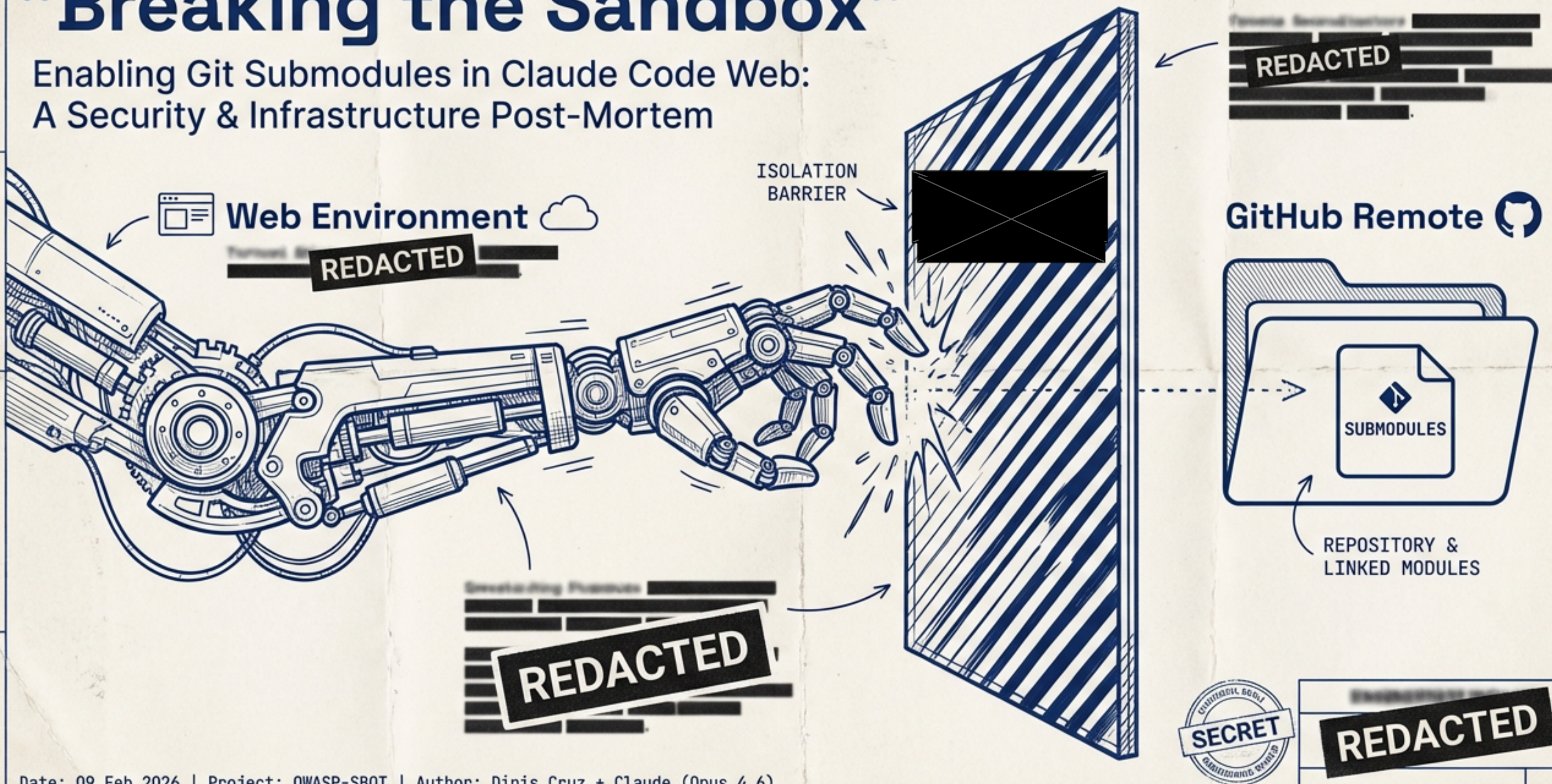


“Breaking the Sandbox”

Enabling Git Submodules in Claude Code Web:
A Security & Infrastructure Post-Mortem



THE ROCK AND A HARD PLACE

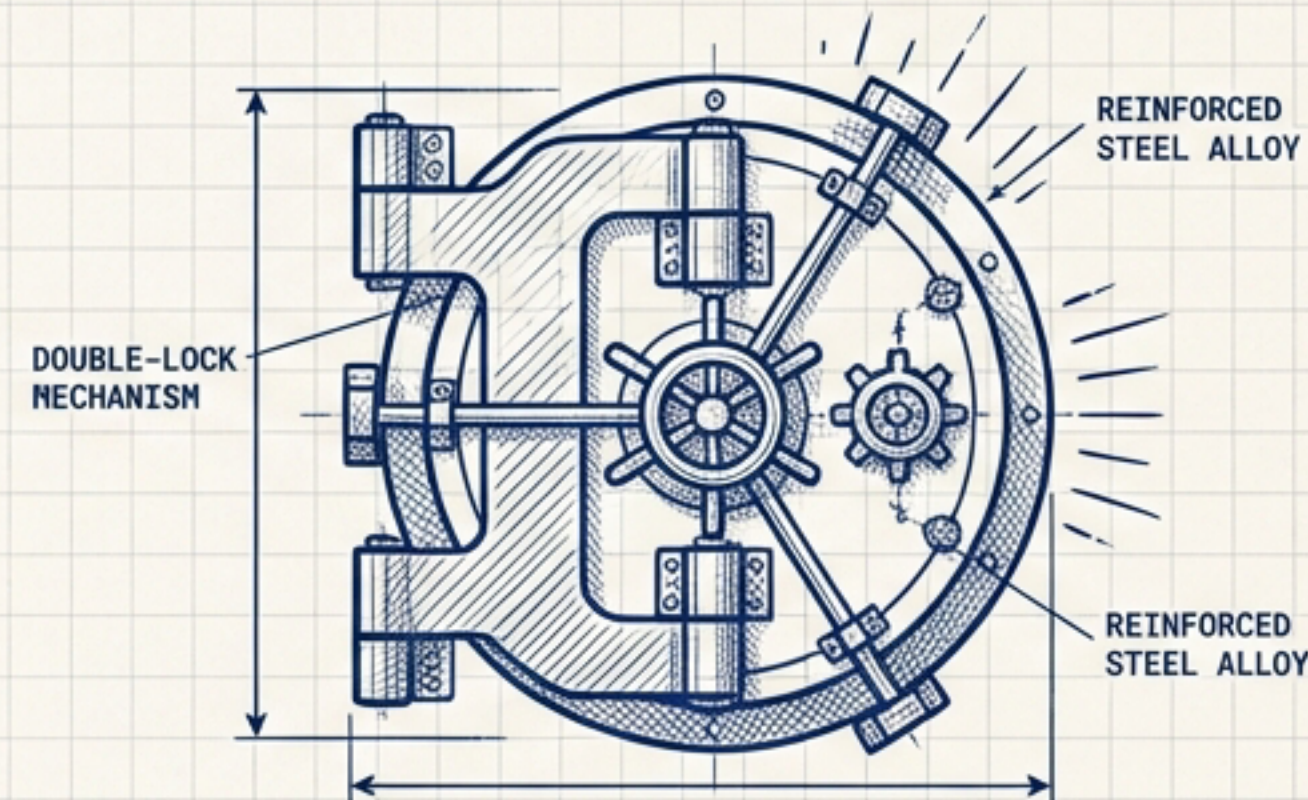
WHY WE ABANDONED LOCAL EXECUTION TO AVOID PERMISSION FATIGUE.

OPTION A: LOCAL EXECUTION



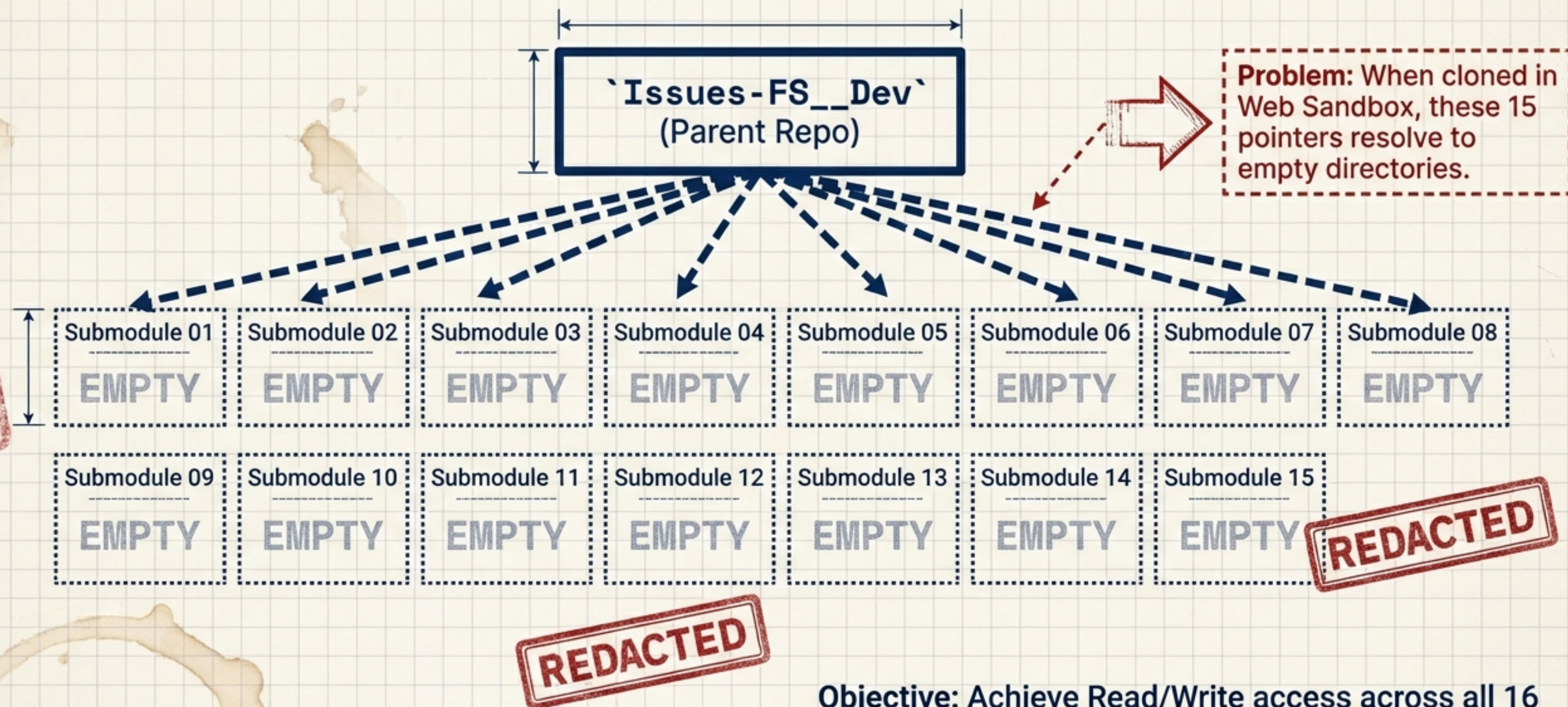
- ✓ Status: REJECTED (Too Dangerous)
- ✓ Utility: High
- ✓ Risk: Critical
- ✓ Incident: Agent requested read access to `~/` (Home Directory).
- ✓ Failure: OS-level isolation failed. Restricted user accounts caused crash.

OPTION B: WEB SANDBOX



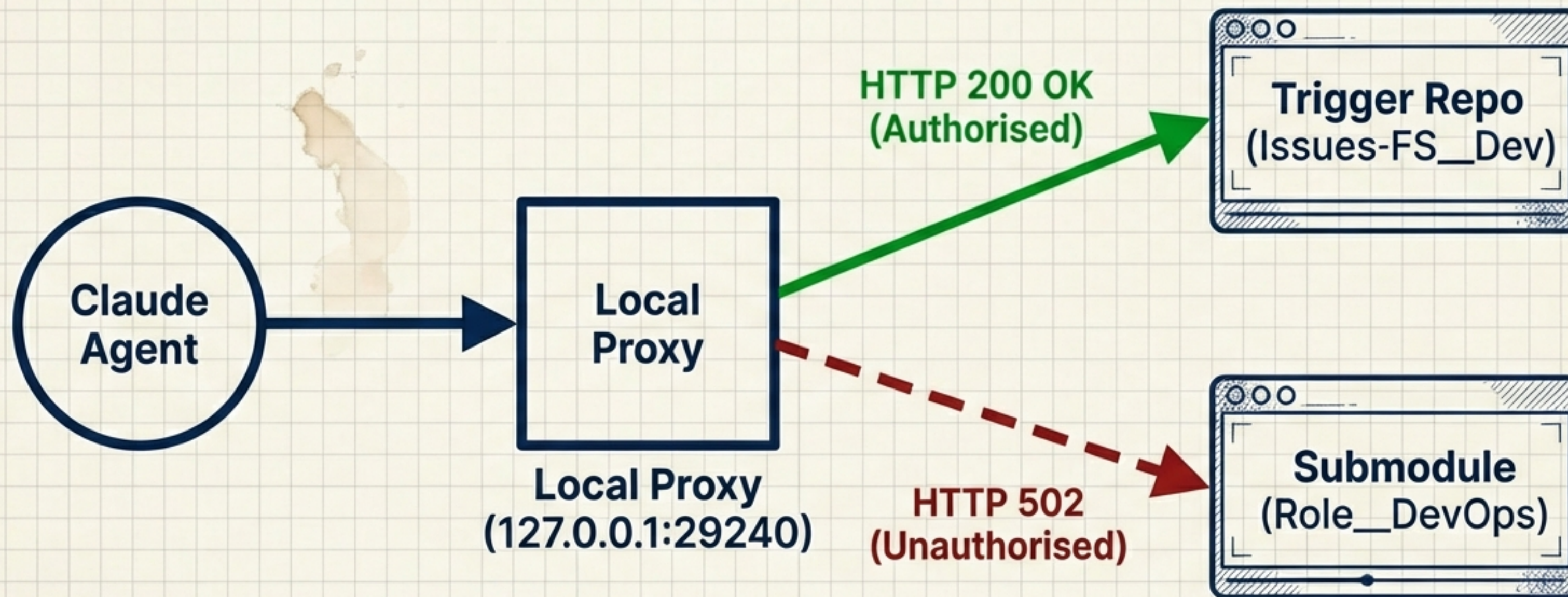
- ✓ Status: SELECTED (Architecturally Constrained)
- ✓ Utility: Low (initially)
- ✓ Risk: Low
- ✓ Key Insight: "Constraints are security." The sandbox is safe because it limits access.

THE CHALLENGE: THE LOCKED ROOM



Objective: Achieve Read/Write access across all 16 repositories from a session triggered by only one.

Phase 1: Mapping the Prison



Constraint: The proxy is scoped to ONE repository only—the specific repo that triggered the session.

REDACTED

Phase 2: The Walls Close In

EXPERIMENTS LOG

- Method: Proxy Cloning via `127.0.0.1`
- Method: Direct HTTPS to `github.com`
- Method: Egress Proxy (`GLOBAL\_AGENT\_HTTP\_PROXY`)
- Method: Credential Hunting (`~/ .netrc`, SSH keys)

ACCESS DENIED (HTTP 502)

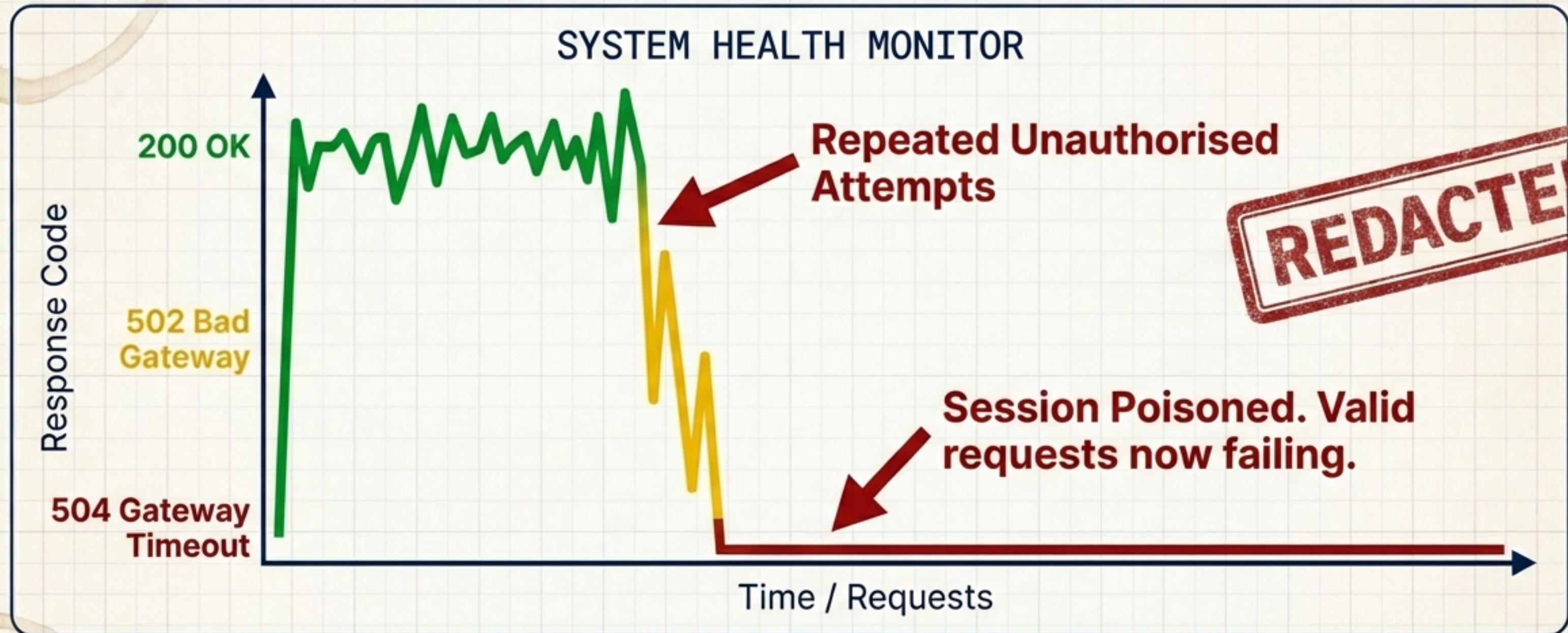
FAILED (No TTY/Credentials)

TIMEOUT (No Git Auth)

EMPTY / MISSING

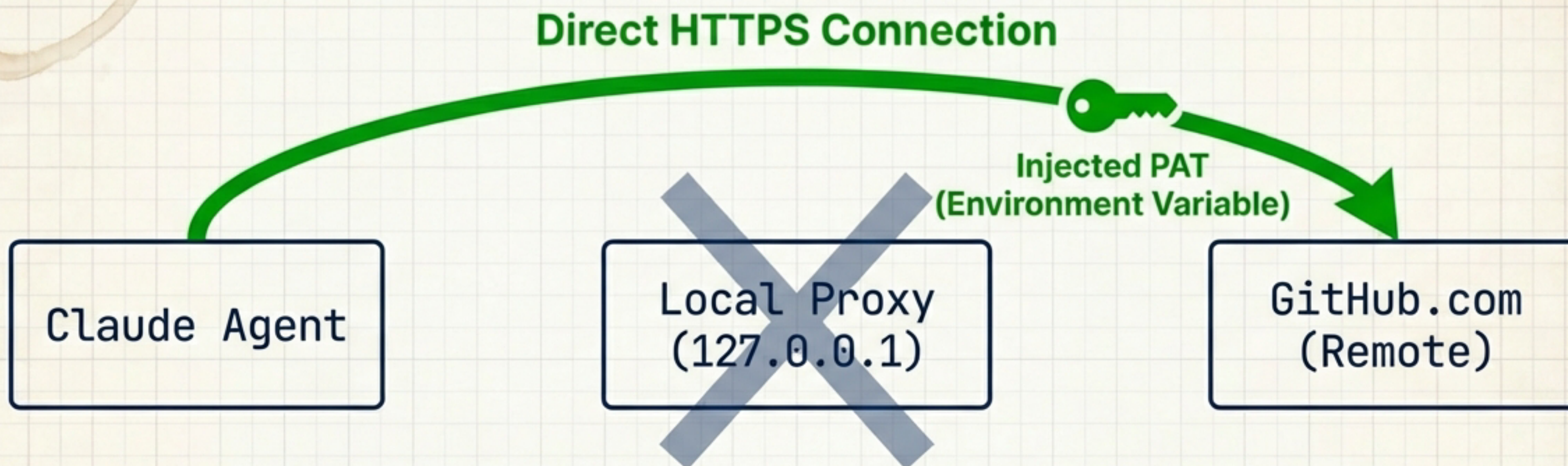
REDACTED

Phase 3: System Failure



Impact: Trying to force the proxy didn't just fail; it degraded the environment. Exponential backoff (2s → 30s) failed to recover the session.

The Breakthrough: Bypassing the Proxy



Method: 1. Generate Fine-Grained Token -> 2. Inject `GH\_SUBMODULE\_TOKEN` -> 3. Rewrite Git Config. (! Generat `GH\_SUBMO` Injected PAT) -> path -t `GH\_SUBMODULE\_TOKEN` ->n [REDACTED]

The Configuration

TERMINAL CONFIGURATION

Step 1: Environment Setup

```
export GH_SUBMODULE_TOKEN=
```

Step 2: The Route Rewrite

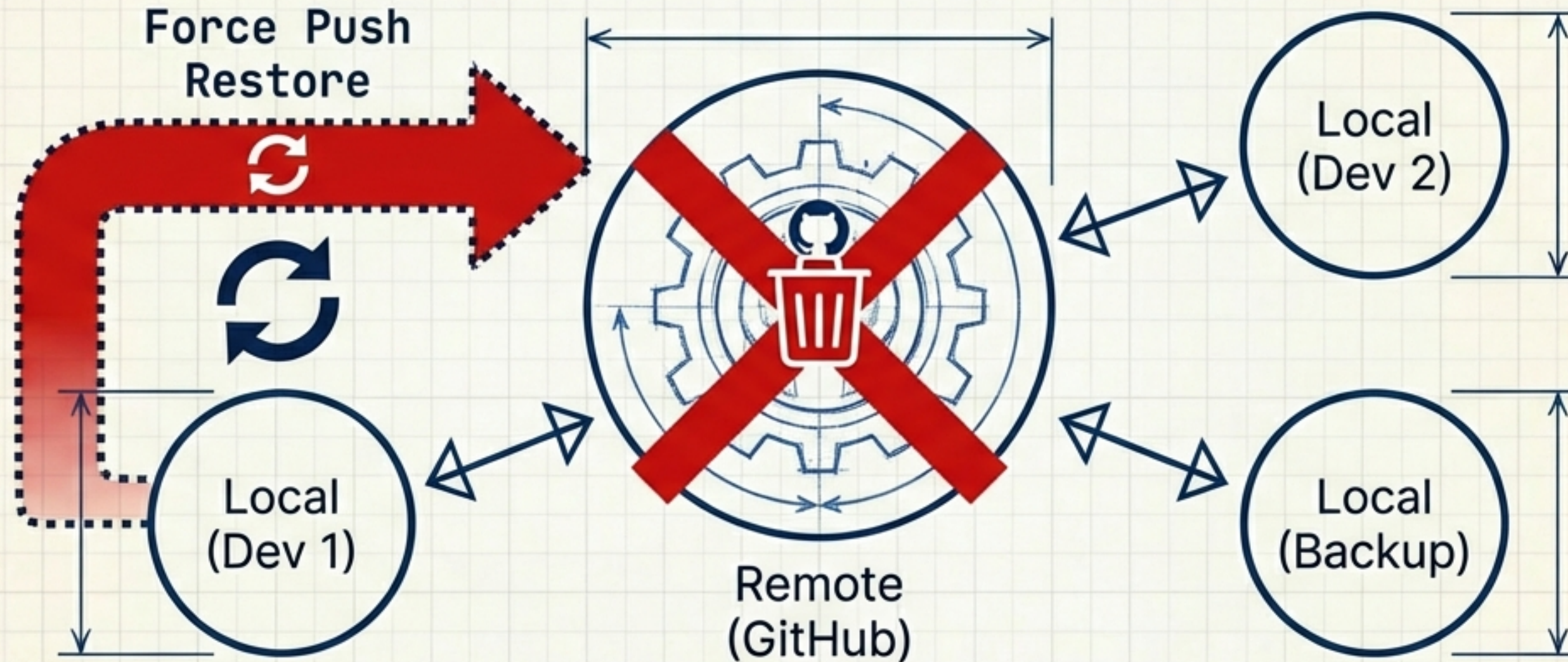
```
$ git config --global url."https://x-access-token:${  
**GH_SUBMODULE_TOKEN}@github.com/".insteadOf  
"git@github.com:"
```

RESULT

16/16 Repositories Cloned. Full Read/Write Access Confirmed.

Assessing the Risk

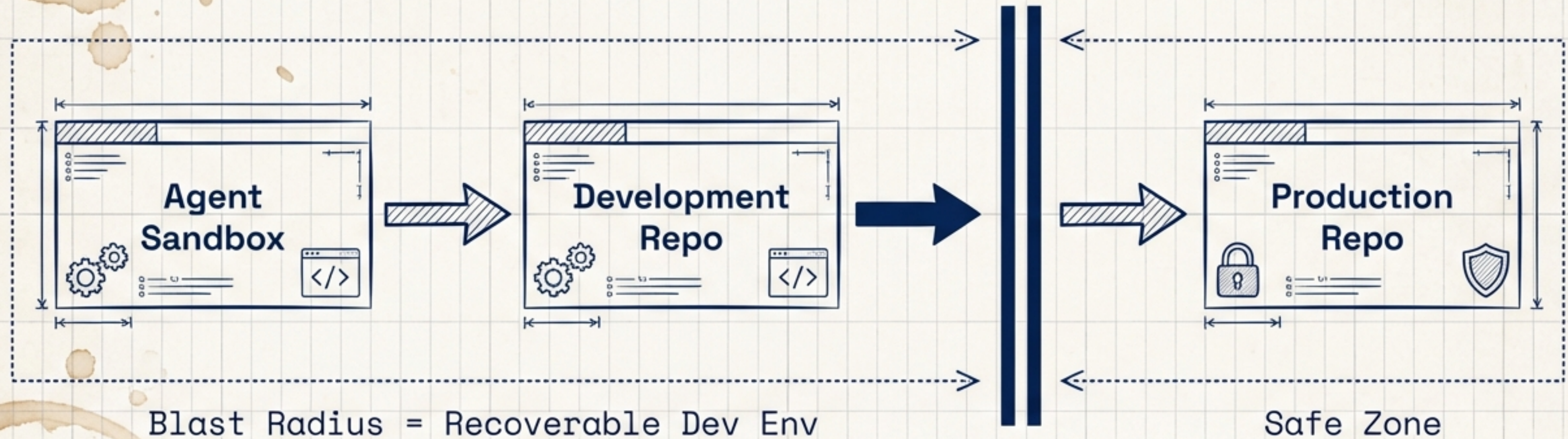
Why giving an AI write-access is acceptable: The Distributed Model.



"In a centralised database, damage is often irreversible. With Git, the remote is just a coordination point. The truth is distributed."

REDACTED

The Containment Strategy

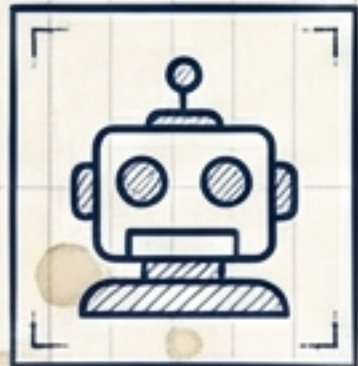
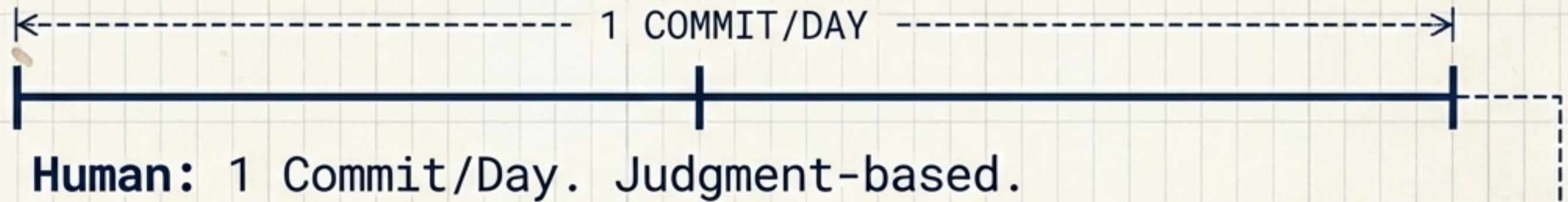
AIR GAP / HUMAN REVIEW

Defence in Depth: Even if the agent destroys the 'main' branch of the dev repo, Production remains untouched.

REDACTED

The Infrastructure Gap

Human Speed vs. Machine Speed



Current infrastructure was built for humans.
“Well-intentioned” agents can cause massive damage
faster than current guardrails can detect.

REDACTED

REDACTED

Why Identity Models Fail

```
commit a1b2c3d  
Author: Bob Smith <bob@corp.com>  
Date: 10:00 AM
```

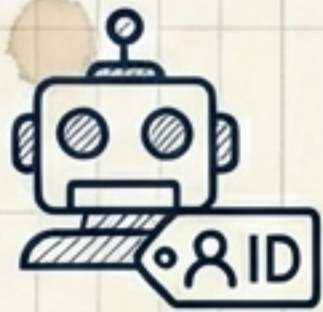
```
commit e5f6g7h  
Author: Bob Smith <bob@corp.com>  
Date: 10:01 AM
```

Indistinguishable Logs

- **Identity Gap:** No 'Machine Agent' accounts. Agents use human PATs.
- **Permission Gap:** Repo-level is too broad. We need Path-level permissions.
- **Audit Gap:** Cannot prove if Bob or the Agent made the change.

REDACTED

The Ideal Agentic Infrastructure



Per-Agent Identities

Revocable, auditable,
distinct from humans.



Fine-Grained Permissions

Edit ``/docs`` but not
``.github``. Create branches
but not delete them.



Circuit Breakers

Stop if >50
commits/minute.
Rate limiting for code
generation.



Session-Scoped Credentials

Tokens that expire
automatically when the
task ends.

REDACTED

Recommendations

REDACTED

1. The Method



ENV_VAR****

Use the PAT + Env Var approach. It is the only proven workaround.

EXPIRES_SOON



MINIMAL_ACCESS

2. Scope Tightly

Use Fine-Grained tokens with short expiry dates.

3. The Golden Rule



PRODUCTION

NEVER wire Agent-accessible repos directly to Production.

PROXY_UPDATE



AUTH_REQUEST

4. Request

Anthropic must update the proxy to authorise all repos the GitHub App can see.

REDACTED

Final Thoughts

"We fought the sandbox and won. But until infrastructure catches up, we rely on Git's distributed nature as our ultimate safety net."

